

业务逻辑漏洞



目录 CONTENTS

01 业务逻辑简介

02 逻辑漏洞简介

03 挖掘思路

01

业务逻辑简介



业务逻辑现状

每个公司或网站都有业务逻辑，因为业务逻辑是组织或应用程序如何运作和执行其主要功能的核心指导原则。

通过了解业务逻辑现状，组织可以更好地规划未来的发展和改进，确保其运作方式与组织的目标和客户需求保持一致。这也有助于识别潜在的问题、瓶颈或改进机会，以提高效率、降低成本和增强业务的竞争力。因此，了解和管理业务逻辑现状对于组织的战略规划和业务管理至关重要。

什么是业务逻辑？

不同的项目有不同的功能，不同的功能需要不同的实现，实现这些核心功能的代码就叫业务逻辑。

比如让你实现一个功能，给你两个数，让你获取它的和，你所写的代码，如何才能让任意给定的两个数的和，这个程序实现过程即可成为业务逻辑处理。

实际上，我们口口声声的业务逻辑，是只用代码实现的真实业务的规则映射。注意“规则”这个词，简单说，一个业务中，存在什么逻辑，可以通过在纸上画出不同业务对象之间的联系和约束，并将这些联系和约束一条条列出来，形成一个列表，而这列表中的每一条，就是一条规则，这些规则的总和，就是这个业务的业务逻辑。

02

逻辑漏洞简介



业务逻辑漏洞的成因

应用程序（软件或者系统）在设计和实施的时候存在缺陷，可能导致系统无法正确处理业务流程，允许攻击者诱发意外行为，像是设计的方案被人钻了空子。

通俗理解就是：在编写程序时，只考虑了常规的操作流程，即“当在A情况下，就会出现B，此时执行C即可”，但是开发者却没有考虑当用户执行了意料之外的X时会发生什么。这种对于异常情况的欠考虑，最终导致了安全漏洞的产生。

常规操作流程（意料之中）：执行A返回B,在执行C A->B->C

意外操作流程：X->??? 执行X返回什么呢？

业务逻辑漏洞的成因

例如：

假设有一个电子商务网站，它提供了优惠券功能，用户可以在结算页面输入优惠券码来获得折扣。网站的业务逻辑是，如果用户输入有效的优惠券码，系统会计算折扣金额并应用于订单总额。然而，由于业务逻辑的设计缺陷，网站存在一个漏洞，导致用户可以通过滥用优惠券功能获得不当的折扣

未对优惠券使用次数进行限制，优惠券码生成算法弱（暴力破解），缺乏验证机制（未验证是否有效），在这样一种情况下我们可以重复使用优惠券码，猜测有效优惠券码，使用无效的优惠券码。

业务流程逻辑点

业务流程逻辑点是指在一个业务流程或应用程序中的关键决策、操作或转折点，它们决定了业务流程的进展和走向。这些逻辑点用于控制业务流程的方向，根据特定的条件或情境来触发不同的操作、决策或功能。在某些情况下，业务流程逻辑点可能与网站的鉴权参数相关联，以确保用户有权访问特定功能或资源。

业务流程逻辑点-每个业务流程逻辑点分类

业务流程逻辑点可能包括以下内容：

用户身份验证：在用户登录网站时，业务流程通常包括一个用户身份验证逻辑点。在这个点上，系统会验证用户提供的凭据（如用户名和密码），以确定用户是否有权访问其帐户。

会话管理：对于已经登录的用户，业务流程中可能会包括会话管理逻辑点。这用于跟踪用户的会话状态，以确保他们在登录后能够访问其帐户和相关资源，而不需要重复身份验证。

角色和权限：网站通常会根据用户的角色和权限来管理其访问权限。业务流程逻辑点可以包括检查用户角色和权限以确定他们是否有权执行特定操作或访问特定页面。

业务流程逻辑点-每个业务流程逻辑点分类

业务流程逻辑点可能包括以下内容：

资源访问：在一些情况下，业务流程可能需要检查用户的权限和访问控制列表，以确定他们是否有权访问特定的资源，如文件、图像、数据库记录等。

交易和支付：对于电子商务网站，业务流程逻辑点可能包括处理支付、订单确认和交付的逻辑。这些点用于确保只有经过授权的用户才能完成交易。

密码重置和安全设置：当用户请求密码重置或更改其安全设置时，业务流程逻辑点用于验证用户身份并执行相应的操作。

日志记录和审计：业务流程逻辑点还可以用于记录用户的活动，以便进行审计和安全监控。

业务流程逻辑点-逻辑点可能存在的位置

URL参数：某些业务逻辑点可能以URL参数的形式传递给服务器。例如，网站可以使用URL参数来指定用户的身份认证状态或请求的页面。

HTTP请求头：用户身份验证信息通常以HTTP请求头中的“Authorization”字段传递给服务器。（Authorization是一个HTTP安全请求首部，包含了客户端提供给服务器 便于对其自身进行认证的数据）

HTTP请求正文：某些逻辑点需要从HTTP请求正文中的JSON、XML或其他数据格式中提取。这可能包括用户提交的表单数据或API请求中的参数。

Cookies：会话管理逻辑点通常使用Cookies来跟踪用户的会话状态。服务器可以在Cookies中存储会话令牌或标识符。

数据库记录：业务逻辑点可以在数据库中存储和管理，例如，用户的角色和权限信息、订单状态、产品库存等。

业务流程逻辑点-逻辑点可能存在的位置

服务器端会话状态：会话管理逻辑点可能依赖于服务器端的会话状态来维护用户的登录状态和会话信息。这些信息通常存储在服务器内存或数据库中。

客户端状态：一些逻辑点可能需要维护客户端状态，如JavaScript中的变量或浏览器本地存储。

日志文件：日志记录和审计逻辑点通常会将用户活动记录到服务器的日志文件中，以供后续审计和监控。

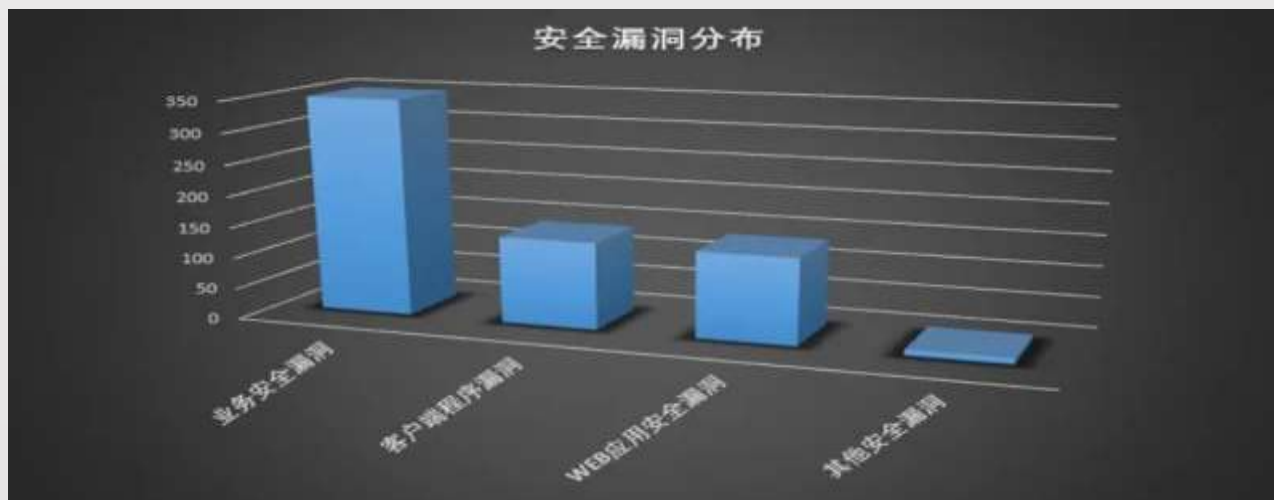
后端应用程序代码：许多逻辑点是通过后端应用程序代码来实现和管理的，例如，用户身份验证、角色和权限检查、资源访问控制等。

前端应用程序代码：一些逻辑点可能在前端应用程序中处理，例如，动态内容控制、用户界面的渲染和交互等。

逻辑漏洞的重要性

常见的OWASP漏洞，通过漏洞扫描工具，大多支持自动化或者半自动化扫描出来；并且传统的安全防御设备和措施收效甚微；

但逻辑漏洞属于和系统自身功能和逻辑有关系的漏洞，每一家的漏洞出现可能存在一定的独特性，很难复制或者通过规则通过脚本扫描，因此逻辑漏洞大多需要配合代码审计和手动测试才可发现相关漏洞，也是工具无法完全替代人所作的一类漏洞；



逻辑漏洞的重要性方面的一些关键考虑

数据泄露和隐私问题：平台没有足够的数据保护措施，用户的敏感信息可能被窃取。

未经授权的访问：攻击者可以访问其他用户的购物车，查看其订单信息，修改订单。

金融损失：用户可能会面临未经授权的支付，导致金融损失。

合规性问题：网站可能面临法律诉讼和罚款，因为其未能遵守数据保护法规。

业务中断：用户无法购物，可能导致业务中断和客户流失。

拒绝服务：平台可能会面临暂时的服务中断，导致用户无法访问或使用平台。

恶意外行为和欺诈：这种欺诈行为可能会导致公司损失，并对品牌声誉产生负面影响。

声誉损害：公司品牌声誉受损，客户会失去信任，并对该网站产生负面印象。

长期存在和影响：用户可能会对网站持怀疑态度，并寻找更安全的购物平台

难以检测：因为它们不涉及常见的安全漏洞模式，如SQL注入或跨站点脚本攻击。

02 逻辑漏洞简介

利用工具

利用工具简单：

数据包抓取工具（**Burpsuit**、**fiddler**等）

浏览器插件

思路复杂：

核心：绕过真实用户身份或正常业务流程达到预期的目的

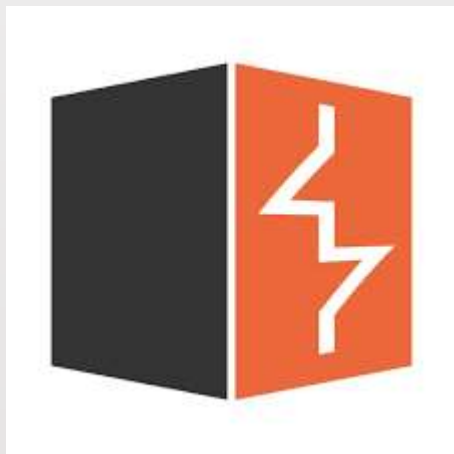


02 逻辑漏洞简介

利用工具

出门佩剑 等等.... 除了这些

Burpsuite, fiddler, postman, Charles 我们还需要细心



 **Progress**[®]
Telerik[®] Fiddler[™]



02 逻辑漏洞简介



电信网厅存在哪些业务流程呢？

核心点-业务流程

对业务的熟悉程度（各种类型的网站、业务模式）

如：电信网厅业务清单图解

网厅

个人信息

话费信息【余额、消费记录、充值记录、话费充值等】

流量信息【余额、消费记录、流量包订购等】

订单信息

账单信息【详细消费记录】

清单信息【详细通话记录】

增至业务信息【增至业务订购】

积分信息【积分兑换、消费记录】

宽带信息【户主信息、宽带办理、障碍保修、电视iTV等】

优惠活动【游戏类、充值办理类、购买类】

核心点-业务流程

列举几个业务，并描述出业务流程

如：网购、开通会员、修改密码等

网购的基本流程

- 1、选择购物平台
- 2、注册账户(开通会员、修改密码)
- 3、搜索商品
- 4、购买商品
- 5、确认收货
- 6、给卖家评分

核心点-业务流程

修改密码

简单来说，是不是要知道原密码才能修改新密码，或者说忘记密码，也得有对应的验证手机号，收取验证码，如果绕过原密码（就是在不知道原密码的情况下）但是通过我们的某些方式绕过了，那是不是就是一个逻辑漏洞，存在任意密码修改这一漏洞。

03

挖掘思路



挖掘思路-业务流程

以下是一些业务逻辑漏洞挖掘思路的案例说明：

边界条件测试：

案例： 一个在线电商网站允许用户设置购物车中的商品数量。攻击者尝试添加负数或极大的数量，以查看是否可以绕过购物车中商品数量的合法性检查。如果能够添加超过库存数量的商品，就可能导致库存错误或不正当购物。

反向思考：

案例： 一个在线银行应用程序允许用户转账。攻击者反向思考，考虑如何在不足额度的情况下执行转账，或者如何绕过二次确认步骤来完成未经授权的交易。

挖掘思路-业务流程

交叉验证:

案例： 一个在线社交媒体平台允许用户删除其发布的帖子。攻击者在删除自己的帖子后，立即尝试将其恢复。通过比较删除和恢复之后的状态，攻击者可以查看是否存在一致性问题。

历史数据分析:

案例： 一个电子邮件服务提供商分析历史登录记录，发现在用户帐户被冻结后，仍然存在多次登录尝试的记录。这表明存在可能的业务逻辑漏洞，导致帐户仍然可以访问。

挖掘思路-业务流程

颠倒顺序:

案例： 一个在线预订系统要求用户先选择日期，然后选择座位。攻击者尝试在未选择日期的情况下选择座位，以查看是否可以绕过日期选择步骤。

重复操作:

案例： 一个在线投票系统允许用户投票一次。攻击者尝试多次投票，查看是否可以绕过投票限制，从而影响投票结果。

越权操作:

案例： 一个医疗记录系统允许医生查看患者的病历。攻击者尝试使用患者的帐户登录，并查看其他患者的病历，以测试是否存在越权漏洞。

挖掘思路-业务流程

并发操作：

案例： 一个在线购物平台允许多个用户同时购买同一商品。攻击者模拟多个用户同时购买相同商品，以查看是否存在库存不一致或订单处理问题。

审查业务逻辑代码：

案例： 安全研究人员审查一个电子投票应用程序的代码，发现在投票结束后，没有正确停止接受新的投票。这导致在投票已结束的情况下仍然能够提交投票，可能影响选举结果。



感谢您的观看

THANKS FOR YOUR WATCHING

